

CODE OF CONDUCT

Version 1.0

Revision Date: July 23, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Code of Conduct
Document ID	POL-COC-001
Current Version	1.0
Approved Date	July 23, 2026
Approved By	Information Security Steering Committee
Effective Date	July 23, 2026
Next Review Date	July 23, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees, contractors, consultants and interns

APPROVAL / OWNER / REVIEWER

Name	Information Security Role	Signature	Date
Madhuri Chandoor	CEO and Founder		July 23, 2026
Praveen Sharma	Security Officer		July 23, 2026

COMPLIANCE

This document supports the SOC 2 Trust Services Criteria CC1.1, CC1.4, CC1.5 (Control Environment), CC2.2, CC2.3 (Communication) and CC3.3 (Fraud Risk). Where the Company processes protected health information or personal data on behalf of clients, it also supports HIPAA Security Rule 45 CFR §164.308(a)(3) and §164.308(a)(5), and GDPR Articles 5, 32 and 33.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 STANDARDS OF INTEGRITY	6
6 PROFESSIONAL CONDUCT IN THE WORKPLACE	7
7 CONFLICTS OF INTEREST	7
8 INDEPENDENCE AND OBJECTIVITY.....	8
9 CONFIDENTIALITY AND CLIENT INFORMATION	8
10 PROTECTION OF ASSETS AND MISUSE OF ACCESS	8
11 USE OF COMPANY SYSTEMS AND ARTIFICIAL INTELLIGENCE TOOLS	9
12 PERSONAL DEVICES AND BRING YOUR OWN DEVICE.....	9
13 FAIR DEALING, GIFTS, AND ANTI-CORRUPTION	10
14 PUBLIC COMMUNICATION AND SOCIAL MEDIA.....	10
15 COMPLIANCE WITH LAWS AND CONTRACTUAL OBLIGATIONS	11
16 REPORTING CONCERNS AND NON-RETALIATION	11
17 ACKNOWLEDGMENT AND TRAINING	12
18 ENFORCEMENT.....	12
19 EXCEPTIONS.....	13
20 REFERENCE.....	13
21 DOCUMENT POLICY HISTORY.....	13

1 Overview and Purpose

PromptHalo Technologies (“the Company”) advises clients on the protection of their most sensitive information and, in doing so, is granted access to systems, data, and business circumstances that clients expect will be treated with integrity. This Code of Conduct defines the ethical standards and expected behavior of all personnel, establishes how concerns are raised and addressed, and evidences the Company’s commitment to integrity and ethical values.

2 Scope

This Code applies to all candidates, employees, officers, contractors, consultants, interns, and temporary workers of the Company, in all locations from which Company business is conducted, including remote work environments and client premises. It applies to conduct during working hours and to conduct outside working hours where that conduct affects the Company, its clients, or its reputation.

This Code is written for a company of the Company's current size and is to be read that way. Unless a clause says otherwise, a requirement to declare, record, review or decide is satisfied by a short, dated note attributable to the person who made it. No clause requires a hotline, an external ethics provider, a committee sitting, an investigator independent of management, or a separate case management system. [SOC 2: CC1.1, CC5.3]

Third parties acting on the Company’s behalf shall be held to equivalent standards through contractual terms managed under the Vendor Management Policy.

3 Roles and Definitions

1. “The Company” refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this policy, oversees its implementation and enforcement, and may delegate specific duties to a designee. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this policy and reviews it at least annually. [SOC 2: CC1.2, CC5.3]

4 Terminology

The following terms have the meanings given below wherever they appear in this policy.

4. **Bring Your Own Device (BYOD)** — a personally owned device used to access Company or client information.
5. **Client information** — any information obtained during an engagement, including vulnerabilities, assessment results, architecture, incident details and personal data.
6. **Conflict of interest** — any circumstance in which personal, financial or outside interests could reasonably be seen to impair objectivity in Company or client work.
7. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.

8. **Independence** — the absence of any relationship or interest that would cause a reasonable person to question the objectivity of a finding or opinion.
9. **Information Security Steering Committee** — the Company's oversight body for information security. At the Company's current size, the Committee comprises the CEO, and every reference in this policy to a decision, approval, review or report of the Committee is satisfied by a dated written record made or confirmed by the CEO; a formal meeting is not required. The Committee's composition is reviewed as the Company grows, and additional members are appointed when an oversight member independent of security operations becomes available. [SOC 2: CC1.2, CC1.3]
1. **Personnel** — all individuals within the scope of Section 2, including employees, officers, contractors, consultants, interns and temporary workers.
2. **Privileged access** — administrative or elevated access to Company or client systems beyond that required by an ordinary user.
3. **Retaliation** — any adverse action taken against a person because they made a good-faith report or participated in an investigation.
4. **Security Officer** — the individual accountable for day-to-day operation of the security program.
5. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment, including a change to the services offered, the systems in scope, the personnel holding privileged access, or the third parties processing client information. [SOC 2: CC3.4]
6. **Subservice organization** — a third party whose controls the Company relies upon and which is carved out of the Company's report.

5 Standards of Integrity

1. Personnel shall act honestly, lawfully, and in good faith in all dealings with clients, colleagues, vendors, regulators, and the public. [SOC 2: CC1.1]
2. Personnel shall not misrepresent their qualifications, certifications, experience, or the scope of work performed, and shall not permit the Company's work product to be represented in a misleading manner. [SOC 2: CC1.1]
3. Assessment findings, control test results, audit evidence, and advisory opinions shall accurately reflect the work performed. Personnel shall not alter, omit, or overstate findings to satisfy a client, a deadline, or a commercial objective. [SOC 2: CC1.1]
4. Company records, timesheets, invoices, and expense claims shall be complete and accurate. [SOC 2: CC1.1]
5. Personnel shall not knowingly make commitments on behalf of the Company that the Company cannot fulfill. [SOC 2: CC1.1]

6 Professional Conduct in the Workplace

1. The Company is committed to a workplace free from harassment, discrimination, bullying, intimidation, and violence. Such conduct is prohibited without exception. [SOC 2: CC1.1]
2. Personnel shall treat colleagues, clients, and vendors with respect and shall not discriminate based on race, color, religion, national origin, sex, sexual orientation, gender identity, age, disability, veteran status, genetic information, or any other characteristic protected by applicable law. [SOC 2: CC1.1]
3. Personnel shall not be under the influence of alcohol or unlawful substances while performing Company work or while present at Company or client premises. [SOC 2: CC1.1]
4. Personnel shall comply with client site rules, safety requirements, and access conditions when working at client locations. [SOC 2: CC1.1]

7 Conflicts of Interest

1. Personnel shall avoid situations in which their personal interests, conflict, or appear to conflict, with the interests of the Company or its clients. [SOC 2: CC1.1, CC3.3]
2. Personnel shall promptly disclose preferably in writing to the Accountable Party any competing financial or business interest in, or relationship with, a vendor, competitor, or client of the Company. This may include ownership interests, board or advisory positions, paid engagements, and close personal relationships with vendor or client personnel involved in the competing Company engagements. Personnel work part-time and routine outside employment unconnected to the Company's vendors, competitors and clients need not be disclosed; where such employment later comes to involve one of them, it shall be disclosed at that point. [SOC 2: CC1.1, CC3.3]
3. Personnel shall not simultaneously advise clients whose interests are directly averse to one another without written disclosure to, and consent from, the affected clients. [SOC 2: CC1.1, CC3.3]
4. Personnel shall not use Company or client information, resources, or business opportunities for personal gain. [SOC 2: CC1.1, CC3.3]
5. Disclosed conflicts shall be recorded, assessed, and managed through documented mitigation, reassignment, or recusal, and reviewed at least annually. [SOC 2: CC1.1, CC3.3]
6. Every person shall complete a conflict-of-interest declaration at least annually and before a new client engagement is accepted. A declaration confirming that no conflict exists is a valid and complete declaration, and the annual declaration may be given as a single line within the annual Code acknowledgment rather than as a separate return. [SOC 2: CC1.1, CC3.3]
7. This section is the Company's conflict of interest policy. No separate conflict of interest document is required, and any reference elsewhere in the Company's documentation to a conflict-of-interest policy is a reference to this section. [SOC 2: CC1.1, CC5.3]

8 Independence and Objectivity

1. Personnel shall form assessment findings, control conclusions, and advisory opinions on the evidence obtained, and shall not allow a commercial relationship, a fee arrangement, or a client's preference to influence them. [SOC 2: CC1.1]
2. Where the Company has designed, implemented, or operated a control, personnel shall disclose that fact in writing before the Company assesses, tests, or opines on that control, and the disclosure shall be recorded in the engagement file. [SOC 2: CC1.1, CC4.1]

9 Confidentiality and Client Information

1. Personnel shall protect the confidentiality of all Company and client information, including client vulnerabilities, assessment results, security architecture, incident details, business plans, and personal data, and shall access such information only as required to perform assigned duties. [SOC 2: CC1.1, C1.1]
2. Client information shall not be disclosed to other clients, prospective clients, or third parties, and shall not be used in marketing, case studies, or public commentary without prior written client authorization. [SOC 2: CC1.1, C1.1]
3. Knowledge of a client's security weaknesses shall never be used for personal advantage, for competitive advantage, or in any manner adverse to that client. [SOC 2: CC1.1, C1.1]
4. Confidentiality obligations survive termination of employment or engagement and shall be reaffirmed in the departure process in accordance with the Human Resources Security Policy. [SOC 2: CC1.1, C1.1]
5. Handling, classification, retention, and disposal of information shall follow the Data Classification Policy and the Data Retention and Disposal Policy. [SOC 2: CC1.1, C1.1]

10 Protection of Assets and Misuse of Access

1. Personnel shall access Company and client systems and data only to the extent required to perform assigned duties, and shall not browse, search, or retrieve information out of curiosity, for personal interest, or for any purpose outside the engagement. [SOC 2: CC3.3, CC6.3]
2. Personnel shall not use privileged or administrative access to obtain a personal, financial, or competitive advantage, to conceal an error or an incident, or to bypass an approval that would otherwise be required. [SOC 2: CC3.3, CC6.3]
3. Personnel shall not retain client data, credentials, assessment evidence, or tooling output after an engagement ends, other than in Company systems under the Data Retention and Disposal Policy, and shall not hold personal copies on personal accounts or devices. [SOC 2: CC3.3, C1.2]
4. Company funds, equipment, software, and time shall be used for Company purposes. Expense claims, timesheets, and invoices shall reflect work performed. [SOC 2: CC3.3]

5. Personnel who become aware of misuse of access, falsification of records, or circumvention of a control shall report it under Section 13. Failure to report known misuse is itself a violation of this Code. [SOC 2: CC3.3, CC4.2]

11 Use of Company Systems and Artificial Intelligence Tools

1. Company systems, accounts, devices, and networks shall be used in accordance with the Acceptable Use Policy and primarily for Company business. [SOC 2: CC1.1, CC6.8, C1.1]
2. Personnel shall not attempt to circumvent security controls, share authentication credentials, or install unauthorized software or services. [SOC 2: CC1.1, CC6.8, C1.1]
3. Personnel shall not input client confidential information, personal data, or Company proprietary information into unapproved services. Company approved artificial intelligence tools are encouraged. [SOC 2: CC1.1, CC6.8, C1.1]
4. Output generated with the assistance of artificial intelligence tools remains the responsibility of the individual who submits it; such output shall be reviewed for accuracy before it is delivered to a client or relied upon in Company work. [SOC 2: CC1.1, CC6.8, C1.1]
5. Personnel shall not perform security testing, scanning, or exploitation activity against any system without documented client authorization defining the permitted scope. [SOC 2: CC1.1, CC6.8, C1.1]

12 Personal Devices and Bring Your Own Device

The Company is remote-first and personnel may use personally owned devices. The following conditions apply to any personal device used for Company or client work.

1. Personnel may use their own laptops, tablets and phones for Company work. The Company does not necessarily require a personal device to be enrolled in central device management at this stage of the Company. [SOC 2: CC6.4]
2. Personnel shall keep client information in Company-managed cloud services and minimize what is stored on a personal device. Where a local copy is genuinely needed to do the work, it shall be deleted once it is no longer required, and in any event at the end of the engagement. [SOC 2: CC6.5, CC6.7]
3. Personnel shall apply the security measures available to them on the devices they use – such as, full-disk encryption, an automatic screen lock, current operating system updates, and the protection built into the platform. Where the Company provides a security tool or a managed device, personnel shall use it as directed; where it does not, these measures are attested at the annual Code acknowledgment rather than enforced by the Company. [SOC 2: CC6.4, CC6.8 · HIPAA §164.310(d)]
4. Information classified Restricted, and any client information the Company holds under an agreement requiring a managed endpoint, shall be accessed only from Company-provided equipment. Where a role needs that access, the Company shall provide the equipment. [SOC 2: CC6.1, CC6.4]

5. Personal accounts, personal cloud storage, personal email and personal artificial intelligence tools shall not be used for client information, and Company information shall not be forwarded to a personal account. [SOC 2: CC6.7]
6. A device used for Company work shall not be shared with family members or others for that work, and Company accounts shall not be signed into on a device belonging to another person. Where a device is shared within a household, Company work shall be done in a separate operating system user account with its own credential. [SOC 2: CC6.1]
7. Personnel shall report loss or theft of a device used for Company work, or any suspected compromise of their credentials, to the Security Officer immediately and in any event within 24 hours. The Company responds by revoking sessions and disabling access; where the Company provided the device or a management tool is in place, it may also wipe Company data. The Company does not access or erase personal content. [SOC 2: CC7.4, CC6.5 · GDPR Art. 33]
8. On termination or at the end of an engagement, access is revoked and personnel shall confirm that local copies of client information have been deleted from their devices. That confirmation forms part of the offboarding record. [SOC 2: CC6.5]
9. Personnel shall acknowledge the remote working requirements of this Code — the measures in this section, and the handling of screens, conversations and printed material away from a Company location — as part of the annual Code acknowledgment. A separate remote working acknowledgment is not required. [SOC 2: CC1.4, CC6.4]

13 Fair Dealing, Gifts, and Anti-Corruption

1. Personnel shall deal fairly with clients, vendors, competitors, and colleagues, and shall not take unfair advantage through manipulation, concealment, abuse of privileged information, or misrepresentation of material facts. [SOC 2: CC1.1, CC3.3]
2. Personnel shall not offer, promise, give, request, or accept any bribe, kickback, or improper payment, directly or through a third party, to obtain or retain business or secure an improper advantage. [SOC 2: CC1.1, CC3.3]
3. Gifts, entertainment, and hospitality shall be modest, infrequent, lawful, and never offered or accepted in circumstances that could influence, or appear to influence, a business decision. Anything of more than nominal value shall be disclosed to the Security Officer. [SOC 2: CC1.1, CC3.3]
4. Personnel shall not make political contributions on behalf of the Company without prior-approval from the CEO. [SOC 2: CC1.1, CC3.3]

14 Public Communication and Social Media

1. Personnel shall not identify a client, describe an engagement, or reference a client's security posture, vulnerabilities, incidents, or tooling in any public forum, including social media, conference material, blog posts, and job histories, without prior written client authorization. [SOC 2: C1.1, CC2.3]

2. Personnel shall not present personal opinions as the position of the Company. Only the CEO, or a person the CEO authorizes in writing, may speak for the Company to media, regulators, or the public. [SOC 2: CC2.3]
3. Vulnerability research and disclosure conducted in a personal capacity shall not use Company or client information, shall be disclosed in advance to the Security Officer where it relates to a technology a client uses, and shall follow coordinated disclosure practice. [SOC 2: CC1.1, CC2.3]
4. Personnel shall not disparage clients, former clients, colleagues, or competitors in public forums, and shall exercise the same discretion online as they would in front of a client. [SOC 2: CC1.1]

15 Compliance with Laws and Contractual Obligations

1. Personnel shall comply with all applicable laws and regulations, including those governing privacy and data protection, export control, intellectual property, employment, and computer misuse. [SOC 2: CC1.1, CC2.3]
2. Personnel shall comply with the security, privacy, and confidentiality obligations the Company owes under client agreements, including any flow-down obligations arising from regulated client environments. [SOC 2: CC1.1, CC2.3]
3. Personnel shall respect the intellectual property rights of others and shall not use unlicensed software, copyrighted material, or third-party proprietary content without authorization. [SOC 2: CC1.1, CC2.3]
4. The legal, regulatory and contractual obligations to which the Company is subject are recorded in the obligations and commitments register maintained under the Information Security Policy. This Code requires compliance with them; the register is where they are listed, and it is not duplicated here. [SOC 2: CC1.1, CC2.3, CC3.1]

16 Reporting Concerns and Non-Retaliation

1. Personnel shall promptly report suspected violations of this Code and unlawful conduct to the Accountable Party. [SOC 2: CC1.1, CC2.2, CC4.2]
2. Concerns regarding the conduct of the Security Officer, or which a person prefers not to raise with the Security Officer, may be reported to ethics@prompthalo.com, which is delivered only to the CEO and is not accessible to the Security Officer. A report may be made without identifying the reporter. This address is the ethics reporting channel referred to in the Information Security Policy. [SOC 2: CC1.1, CC2.2]
3. Where a concern involves the conduct of the CEO, it may be raised with the Company's external counsel or accountant, when appointed and when the company grows to 50 employees, whose contact details the CEO shall make available to all personnel. At the Company's size an internal route independent of the CEO does not exist, and naming an external recipient is the compensating measure. [SOC 2: CC1.1, CC1.2]

4. Suspected security incidents and security weaknesses shall additionally be reported in accordance with the Incident Response Plan. [SOC 2: CC1.1, CC2.2, CC4.2]
5. Reports may be made confidentially and, where permitted by applicable law, anonymously. [SOC 2: CC1.1, CC2.2, CC4.2]
6. The Company prohibits retaliation against any individual who reports a concern in good faith or participates in an investigation. Retaliation is itself a violation of this Code and is subject to disciplinary action. [SOC 2: CC1.1, CC2.2, CC4.2]
7. Reports shall be investigated promptly and proportionately, documented, and handled with confidentiality appropriate to the circumstances. [SOC 2: CC1.1, CC2.2, CC4.2]
8. Suspected fraud, including fraudulent reporting, misappropriation of assets and circumvention of controls, is handled under this Code's reporting and enforcement provisions rather than under a separate process. Where no fraud or conduct case arose in the year, a nil return shall be recorded in the annual risk assessment; the absence of cases is itself the evidence and requires no additional exercise. [SOC 2: CC3.3, CC1.1]

17 Acknowledgment and Training

1. All personnel shall acknowledge this Code in writing upon hire or engagement, upon material revision, and at least annually thereafter, as a condition of employment or engagement. [SOC 2: CC1.1, CC1.4]
2. Acknowledgment records shall be retained by the Security Officer as evidence of the Company's control environment. [SOC 2: CC1.1, CC1.4]
3. The acknowledgment record shall identify the individual, the version of this Code acknowledged and the date. On material revision, outstanding acknowledgments shall be reset so that acceptance is recorded against the current version rather than a superseded one. [SOC 2: CC1.1, CC2.2]
4. This Code is published by name in the policy repository with its approval date and version recorded, and personnel are notified on issue. The approval date and the approving party are recorded in the Governance Decisions Log maintained under the Information Security Policy. [SOC 2: CC1.1, CC2.2, CC5.3]
5. Ethics and conduct expectations shall be included in the Company's security awareness and training program and reinforced at least annually in accordance with the Security Awareness and Training Policy. [SOC 2: CC1.1, CC1.4]
6. Background screening shall be completed in accordance with the Human Resources Security Policy before access to Confidential or Restricted data is granted. [SOC 2: CC1.1, CC1.4]

18 Enforcement

1. Violations of this policy may result in disciplinary action up to and including termination of employment or engagement, and, where applicable, civil or criminal referral. [SOC 2: CC1.5]

2. Disciplinary decisions shall be documented by the Security Officer and applied consistently, in accordance with the Company's personnel sanctions process. [SOC 2: CC1.5]
3. The Security Officer documents the finding and recommends action; the CEO determines the outcome, documents it, applies it consistently across comparable cases, and retains the personnel record. Where an outcome departs from that reached in a comparable case, the reason shall be recorded. [SOC 2: CC1.5, CC1.1]
4. Each conduct deviation shall be recorded at the time with three elements: the finding, the decision taken, and the rationale for it. A dated note of a few sentences is sufficient, and a record shall be made even where the decision is to take no further action. [SOC 2: CC1.1, CC1.5]
5. Failure to report a known violation, or interference with an investigation, may itself result in disciplinary action. [SOC 2: CC1.5]

19 Exceptions

Exceptions to this policy must be requested in writing to the Security Officer and approved by the Information Security Steering Committee before taking effect. Approved exceptions shall be documented, risk-assessed, time-bound, and reviewed at least annually. No exception may be granted to the prohibitions on harassment, discrimination, retaliation, bribery, or unlawful conduct.

20 Reference

1. SOC 2 Trust Services Criteria, Security category [CC1.1, CC1.4, CC1.5, CC2.2, CC3.1, CC3.3]
2. POL-AUP-001 Acceptable Use Policy [SOC 2: CC1.1, CC1.5]
3. POL-DCL-001 Data Classification Policy [SOC 2: CC1.1]
4. POL-SAT-001 Security Awareness and Training Policy [SOC 2: CC1.4, CC2.2]
5. POL-IRP-001 Incident Response Plan [SOC 2: CC2.2, CC7.3]
6. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
7. POL-ISP-001 Information Security Policy [SOC 2: CC3.1, CC1.2]
8. POL-HRS-001 Human Resources Security Policy [SOC 2: CC1.1, CC1.4]
9. POL-RSK-001 Risk Management Policy [SOC 2: CC3.3]
10. HIPAA Security Rule, 45 CFR §164.308(a)(3) and §164.308(a)(5)
11. EU General Data Protection Regulation, Articles 5, 32 and 33

21 DOCUMENT POLICY HISTORY

Version	Date	Description
1.0	July 23, 2026	Initial policy release